

Botium Toys Cybersecurity Audit

Stakeholder Memorandum

TO: IT Manager, Stakeholders
FROM: Rihanullah Aman, Security Analyst
DATE: August 7, 2026
SUBJECT: Internal IT Audit Findings and Recommendations

This memo summarizes the findings and recommendations from the recently completed internal cybersecurity audit of Botium Toys' IT infrastructure and security program.

Audit Scope

The audit assessed the full scope of Botium Toys' assets, internal processes, and procedures, including current controls, user access, and alignment with applicable compliance requirements (PCI DSS, GDPR, and SOC).

Key Findings

- Botium Toys currently lacks several foundational administrative controls, including least privilege access, separation of duties, and a formal disaster recovery plan.
- Credit card and customer data are not encrypted, and all employees currently have access to sensitive internal data, including PII/SPII — posing a direct compliance risk under PCI DSS and GDPR.
- No intrusion detection system (IDS) or centralized password management system is in place.
- Physical security controls (locks, CCTV, fire detection/prevention) and basic technical controls (firewall, antivirus) are already in place and functioning well.
- Overall risk was scored 8 out of 10, reflecting a high level of exposure primarily driven by gaps in access control and data protection rather than physical security.

Recommendations

To reduce risk and bring Botium Toys into closer alignment with PCI DSS, GDPR, and SOC best practices, I recommend the following be prioritized:

- Implement least privilege access controls and separation of duties across all systems handling sensitive data.
- Encrypt customer PII and credit card information in storage and in transit.
- Deploy an intrusion detection system (IDS) and adopt a centralized password management system.
- Develop and formalize a disaster recovery plan, including regular automated backups.
- Enable multi-factor authentication (MFA) for all staff logins.

Next Steps

The full controls and compliance checklist, including detailed yes/no assessments against each control and regulation, is attached for reference. I welcome the opportunity to discuss prioritization and timelines with stakeholders at your convenience.

Thank you for your continued support in strengthening Botium Toys' security posture.

Sincerely,

Rihanullah Aman
Security Analyst
Botium Toys